Trickbot - WIZARD SPIDER

Dissecting a financial-sector malware sample: behavior, evasion, persistence and command-and-control

Scenario	A financial organization detected unauthorized attempts to reach sensitive financial records. A suspicious executable was recovered and handed over for analysis.
Objective	Dissect the sample, document how it behaves on a Windows host, map its techniques to MITRE ATT&CK, and identify the infrastructure it talks to.
Sample SHA-256	3bf0f489250eaaa99100af4fd9cce3a23acf2b633c25f4571fb8078d4cb7c64d
Tools	PowerShell (`Get-FileHash`), VirusTotal (Behavior, Relations, Graph), Hybrid Analysis
Approach	Hash the sample, pivot into public sandbox reports, follow what the sample drops, then pivot again on the dropped file.

Summary

The sample is a Trickbot-family dropper. Behavioral data shows it fingerprints the host through WMI before committing to execution, hides inside **explorer.exe** through process injection and thread execution hijacking, drops a secondary payload named **TimeManager.exe** into **C:\ProgramData**, and registers that payload under the current-user **Run** key so it survives logoff and reboot. The dropped payload is flagged by 54 of 71 vendors and reaches out to a known malicious domain and several Russian-hosted IP addresses, which points to active command-and-control.

PHASE 1 Sample Identification

The investigation starts with the recovered executable. Its SHA-256 was calculated in PowerShell with `Get-FileHash -Algorithm SHA256`, which gives a stable fingerprint that can be searched in public malware databases without ever executing the file.

The hash was then submitted to VirusTotal and the **Behavior** tab was opened. The activity summary already carries two sandbox verdicts: Zenbox flags the file as a malware evader and CAPE Sandbox flags it as malware. That early hint of evasion shaped the rest of the analysis.

PHASE 2 WMI Interaction and Environment Fingerprinting

Expanding the MITRE ATT&CK section of the behavior report shows **Windows Management Instrumentation (T1047)** under the Execution tactic, with three supporting observations:

- A connection to the WMI namespace is made through **WbemLocator**, the COM component used to reach WMI.

- BIOS information is queried through **Win32_Bios**.
- System information is queried through **Win32_ComputerSystem**, a query commonly used to spot virtual machines.

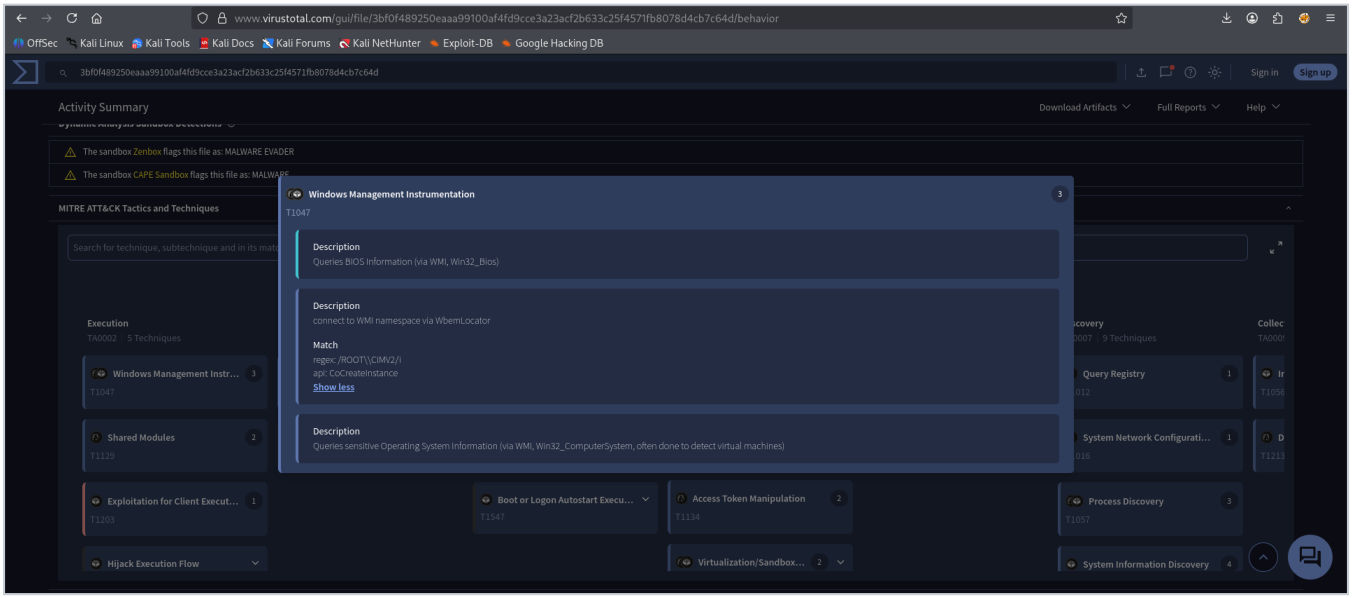


Figure 1 - WMI behavior (T1047): WbemLocator connection plus Win32_Bios and Win32_ComputerSystem queries.

Reading BIOS and system model data lets the malware decide whether it is running inside an analysis sandbox. If it is, it can change behavior or stop, which explains the evader flags seen in Phase 1. WMI is also attractive to attackers because it is a built-in, trusted interface that avoids many of the API calls security products watch.

PHASE 3 Evasive Code Execution

Under the Defense Evasion tactic, the report lists **Process Injection (T1055)** and, as a sub-technique entry, **Thread Execution Hijacking (T1055.003)**. The behaviors attached to it describe the full injection chain:

- Memory is allocated inside a foreign process and a PE file is injected into it.
- Data is written to foreign memory regions and a thread is created in the other process.
- Code is injected into the **Windows Explorer (explorer.exe)** process, and a system process then makes network connections, which the sandbox attributes to injected code.

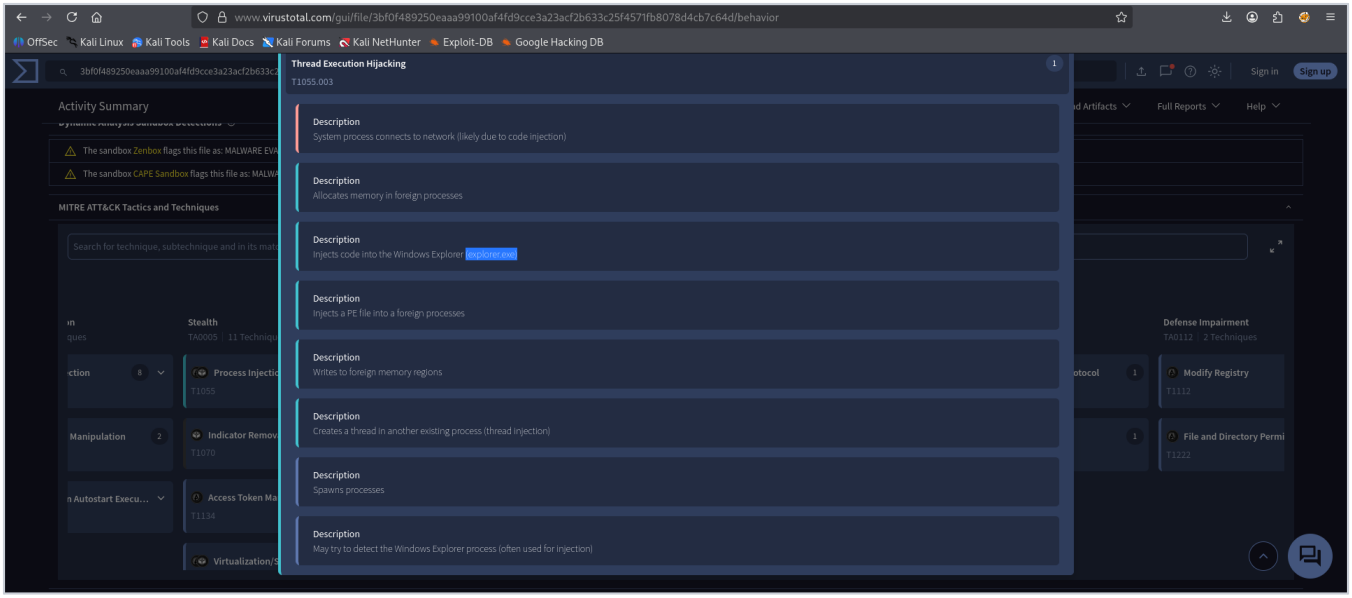


Figure 2 - Thread Execution Hijacking (T1055.003): injection into explorer.exe highlighted.

Running inside **explorer.exe** is a smart choice for the attacker. It is a core Windows process that is always present, its network and file activity looks routine, and injected code inherits the privileges of the host process. Because the malicious activity does not come from a standalone executable, behavior-based detection has a harder job.

PHASE 4 Payload Dropping

Next, the **File system actions** section of the behavior report was reviewed. Under *Files Written*, two entries appear in **C:\ProgramData**: a **Time Manager** entry and the executable **TimeManager.exe**. This is the secondary payload delivered by the dropper.

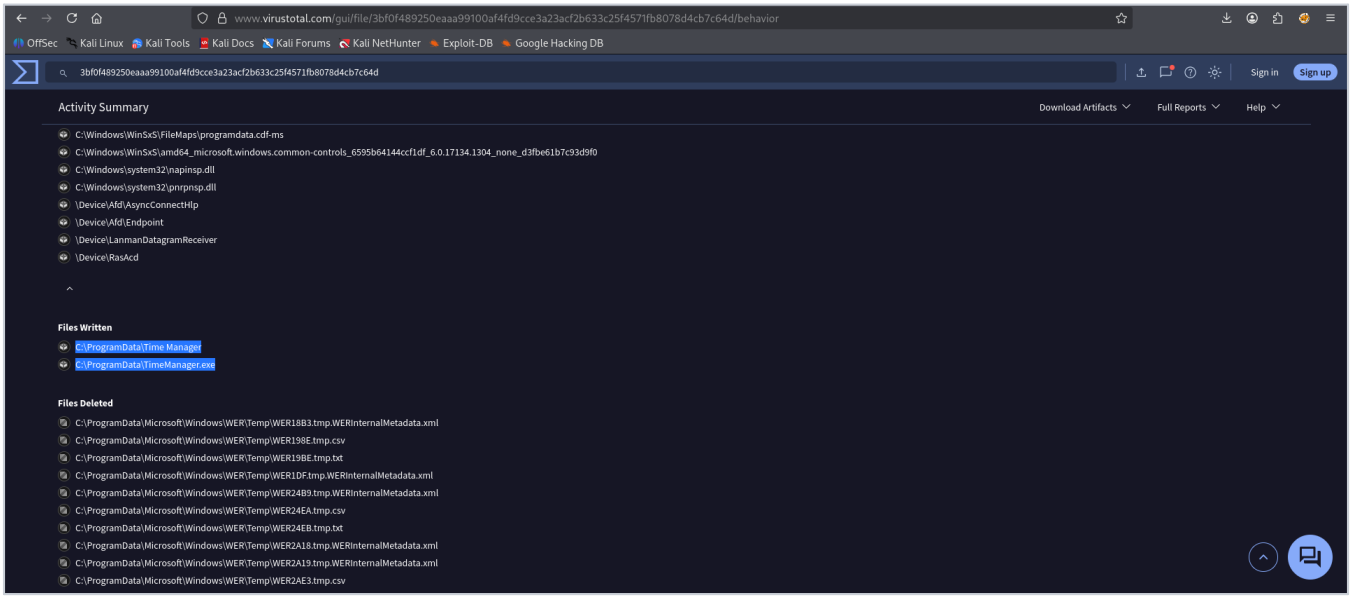


Figure 3 - Files Written: C:\ProgramData\Time Manager and C:\ProgramData\TimeManager.exe.

Two details stand out. **C:\ProgramData** is a directory legitimate software also uses for components and configuration, so a file there draws little attention. The name **TimeManager.exe** imitates a harmless utility, which lowers suspicion from both users and analysts. The long list of deleted Windows Error Reporting temp files in the same view is a side effect of the sample's activity and is worth noting as background noise.

PHASE 5 Persistence

The registry activity section was then examined to learn how the dropped file survives a restart. Among the registry keys touched by the sample is the current-user autorun location:

```
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
```

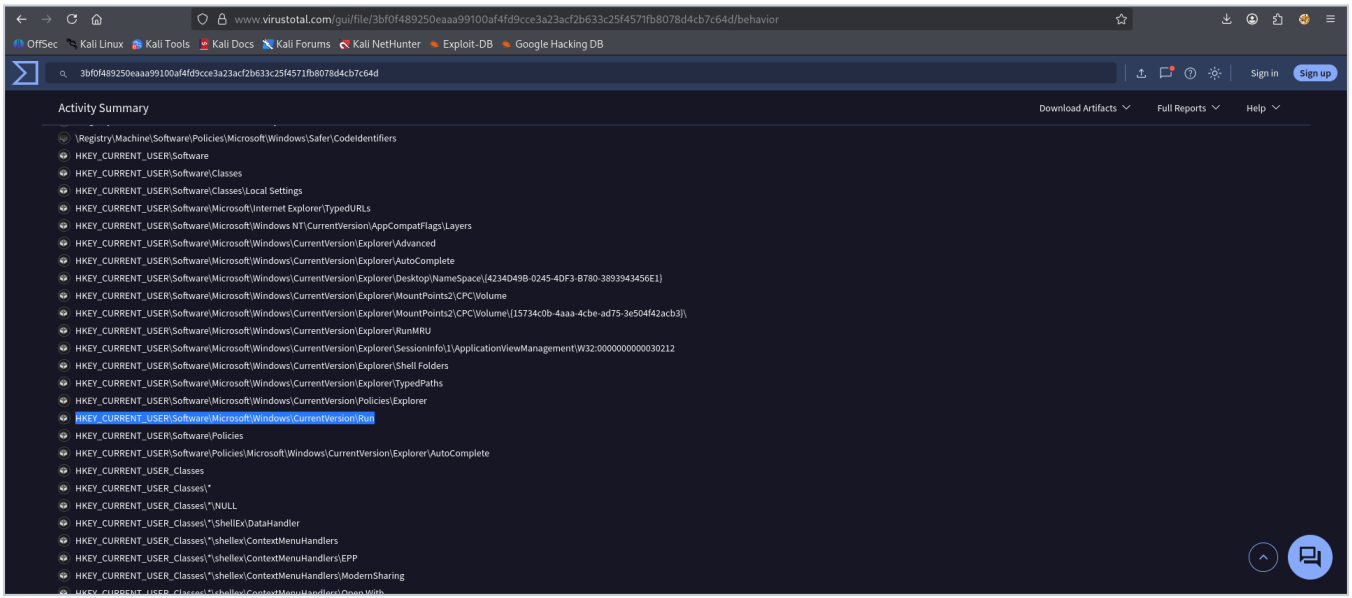


Figure 4 - Registry keys opened or set, with the CurrentVersion\Run key highlighted.

The behavior report also lists **Modify Registry (T1112)**, backed by registry API calls such as RegOpenKeyEx and RegDeleteValue, which confirms the sample actively works with the registry rather than merely reading it.

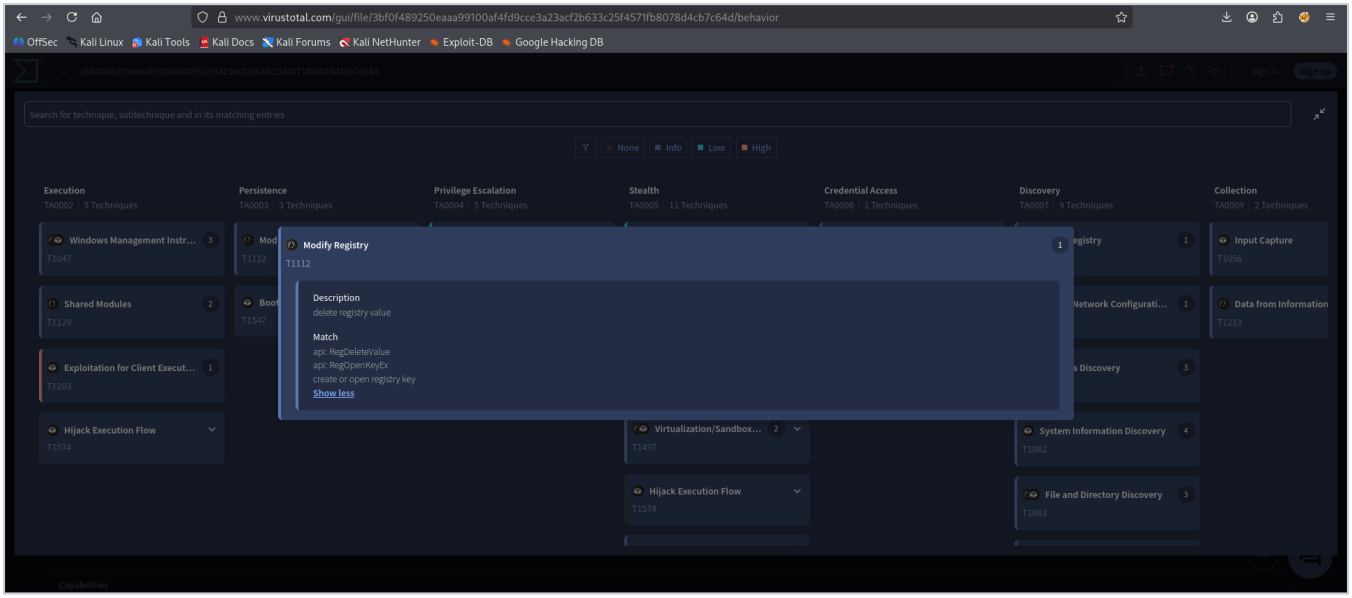


Figure 5 - Modify Registry (T1112): registry value deletion and registry key open/create activity.

Entries under the **Run** key launch the referenced program every time the user logs on. Pointing it at **C:\ProgramData\TimeManager.exe** ties the persistence mechanism directly to the payload found in Phase 4. Using the *HKEY_CURRENT_USER* hive needs no administrator rights and only affects the logged-in user, which makes it simple to deploy and easy to miss for tools that focus on machine-wide autoruns.

PHASE 6 Relationship Mapping

To see the sample as a whole, a VirusTotal Graph was built from its hash. The first view shows the sample at the center with branches for contacted IP addresses, contacted domains, dropped files, execution parents, PE resource children and the collections it belongs to.

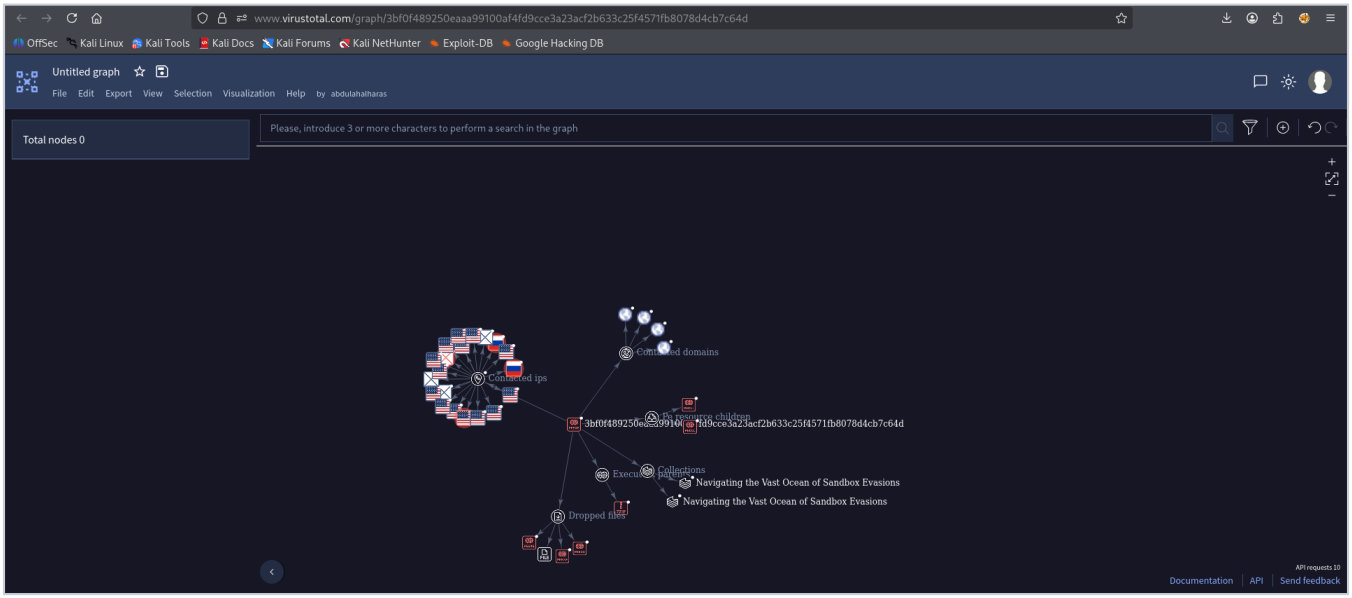


Figure 6 - VirusTotal Graph for the original sample: contacted IPs and domains, dropped files and parents.

Expanding the dropped-file branch and selecting the executable node gives the properties of the dropped payload: a 192 KB Win32 EXE named **TimeManager.exe**, first seen 2022-12-28, with **54/71** detections. Its own relations fan out to a large set of contacted IP addresses, many flagged with Russian flags, plus a contacted domain.

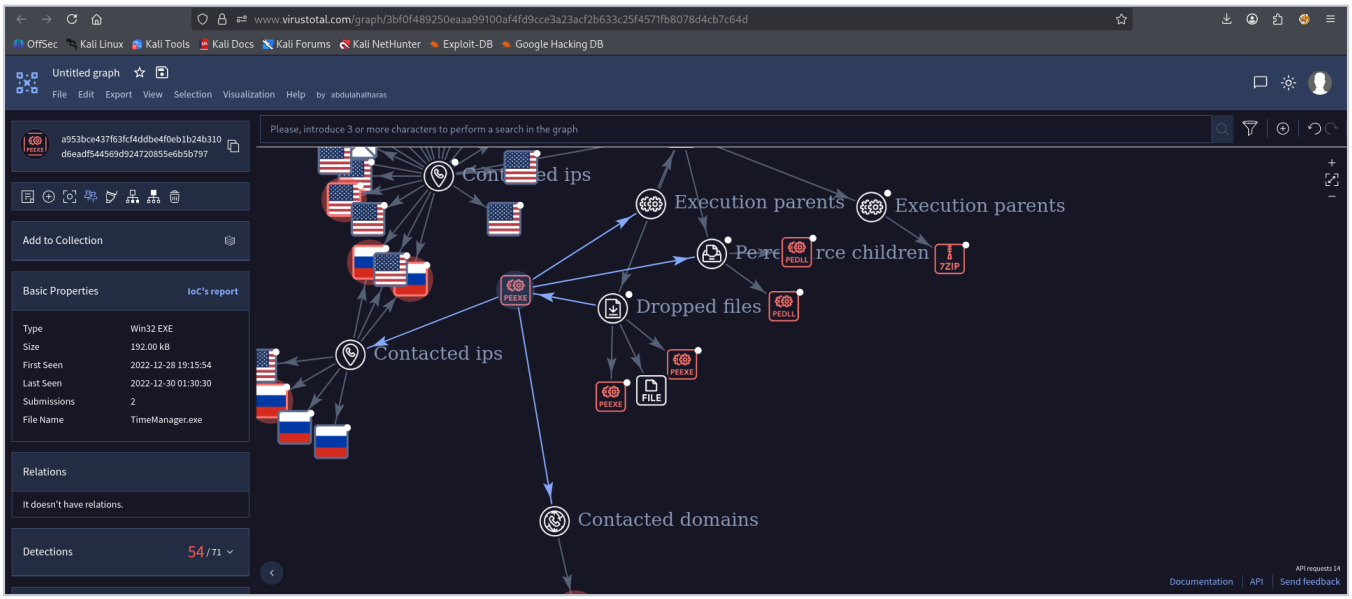


Figure 7 - Dropped payload node in the graph: Win32 EXE, 192 KB, TimeManager.exe, 54/71 detections.

Dropped payload SHA-256:

```
a953bce437f63fcf4ddbe4f0eb1b24b310d6eadf544569d924720855e6b5b797
```

PHASE 7 Sandbox Corroboration

The dropped payload was also checked in Hybrid Analysis to confirm the picture from a second source. The report, generated by Falcon Sandbox on a Windows 10 64-bit guest, rates it **malicious** with a threat score of **100/100** and the **#evasive** tag.

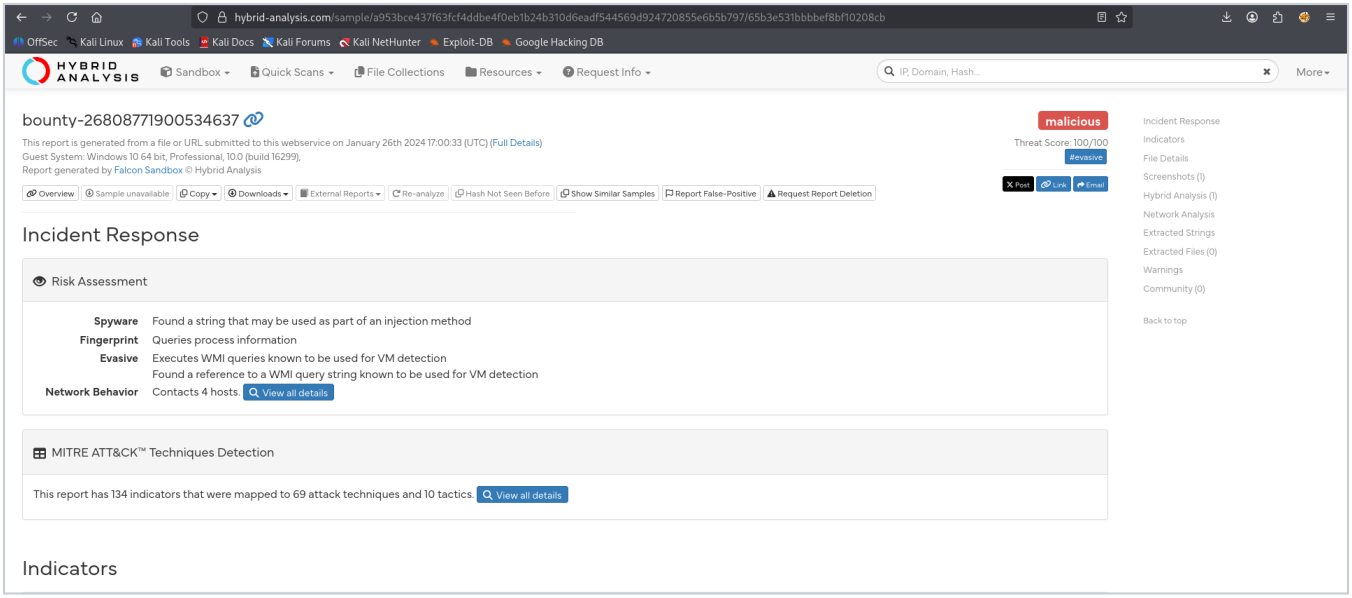


Figure 8 - Hybrid Analysis incident response summary: malicious, threat score 100/100.

- **Spyware:** a string that may be part of an injection method was found.
- **Fingerprint:** the sample queries process information.
- **Evasive:** it runs WMI queries known to be used for virtual machine detection.
- **Network behavior:** it contacts four hosts.
- 134 indicators were mapped to 69 attack techniques across 10 tactics.

These results agree with the behavior seen earlier: WMI-based environment checks, injection-related strings and active network use.

PHASE 8 Command-and-Control Infrastructure

Finally, the **Relations** tab of the dropped payload in VirusTotal was opened. It is flagged by **54 of 71** vendors and lists one contacted domain and seven contacted IP addresses.

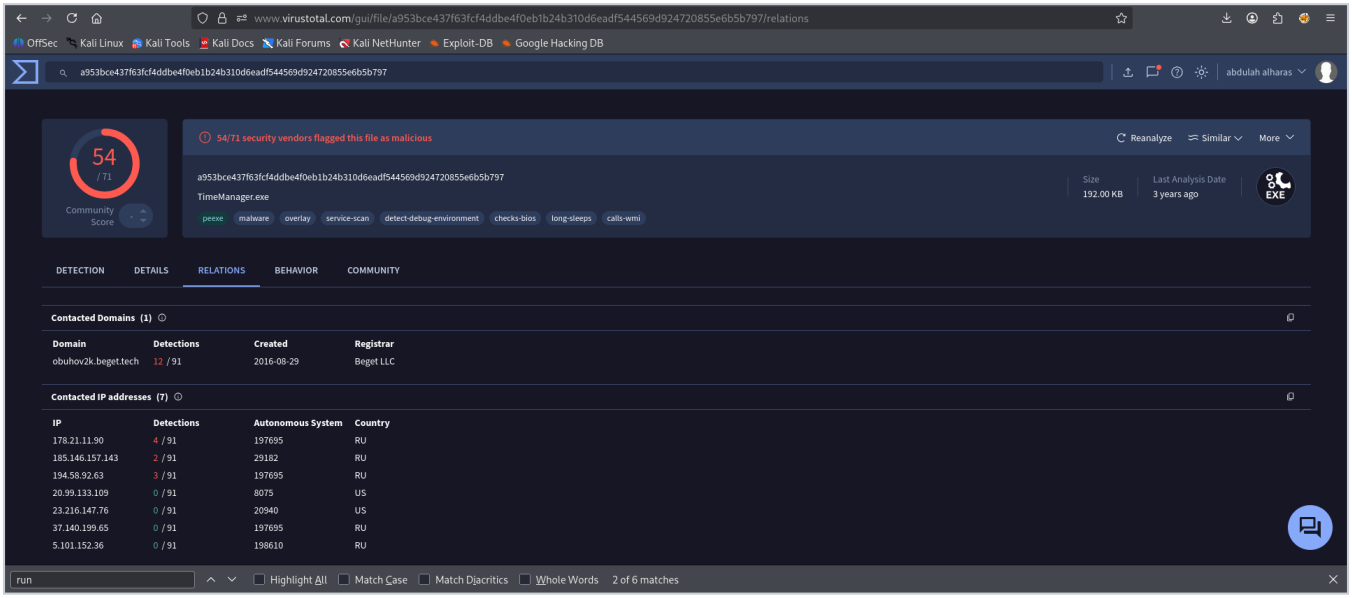


Figure 9 - Relations tab for TimeManager.exe: contacted domain and contacted IP addresses.

Indicator	Type	Detections	Notes
`obuhov2k.beget.tech`	Domain	12 / 91	Registrar Beget LLC, created 2016-08-29
`178.21.11.90`	IP	4 / 91	AS197695, RU
`185.146.157.143`	IP	2 / 91	AS29182, RU
`194.58.92.63`	IP	3 / 91	AS197695, RU
`37.140.199.65`	IP	0 / 91	AS197695, RU
`5.101.152.36`	IP	0 / 91	AS198610, RU
`20.99.133.109`	IP	0 / 91	AS8075, US
`23.216.147.76`	IP	0 / 91	AS20940, US

The domain **obuhov2k.beget.tech** is flagged as malicious by 12 vendors and is the malware's main outbound destination. Most contacted IPs sit in Russian autonomous systems and several are flagged, while the US-based addresses with zero detections are more likely ordinary Windows or CDN traffic. Together they show the dropped payload keeps a channel open to remote infrastructure that can be used for remote access, data theft or delivery of further modules. This matches Trickbot's modular design, which has been used for financial fraud and credential theft.

Key Findings

Area	Finding
Fingerprinting	WMI via WbemLocator; Win32_Bios and Win32_ComputerSystem queries for VM detection
Defense evasion	Process injection and thread execution hijacking into explorer.exe
Dropped payload	C:\ProgramData\TimeManager.exe
Persistence	HKCU\Software\Microsoft\Windows\CurrentVersion\Run
C2	obuhov2k.beget.tech and multiple Russian-hosted IP addresses

MITRE ATT&CK Mapping

Tactic	Technique	ID
Execution	Windows Management Instrumentation	`T1047`
Defense Evasion	Process Injection	`T1055`
Defense Evasion	Thread Execution Hijacking	`T1055.003`
Defense Evasion	Modify Registry	`T1112`
Persistence	Registry Run Keys / Startup Folder (autostart execution)	`T1547`

Detection and Mitigation

- Monitor registry writes to **Run**, **RunOnce** and Startup locations, and alert on entries that point to non-standard paths such as C:\ProgramData.
- Use EDR rules for cross-process memory allocation, remote thread creation and writes into explorer.exe.
- Log WMI activity and look for unusual queries to Win32_Bios and Win32_ComputerSystem from non-administrative tools.
- Block and alert on traffic to the identified domain and IP addresses, and hunt for TimeManager.exe in ProgramData across the estate.
- Audit autorun entries regularly and restrict who can write executables to shared directories.

Conclusion

Using only hash-based pivoting and public sandbox data, the sample was traced from a single file to its complete kill chain: environment checks, injection into a trusted process, a dropped second-stage executable, registry persistence and outbound C2 contact. The exercise reinforces how much can be learned from behavioral reports and relationship graphs without detonating malware locally.